

Re-verification — Systemic API SQL-leak / input-validation defect

Component: Backend API (cross-cutting) · Environment: QA [acme.qa.egalvanic.ai](#) · Verified: **2026-07-31**, authenticated Super-Admin session (cookie auth) · App badge: V1.36

✅ **RESOLVED** — all 10 enumerated ticket vectors fixed. No SQL / psycopg2 / traceback / schema text in any response.

Malformed input now returns a clean HTTP 400 (or 404-class); abusive pagination degrades to a clamped 200; genuine errors return a generic message + trace_id only. The building/create control still returns its clean 400, and that discipline is now applied across the surface. One **adjacent, lower-severity** gap remains (create endpoints accept some invalid-but-well-formed payloads with 201) — separate from this info-disclosure defect; see below.

Vector-by-vector result (live probes, this session)

Vector	Endpoint · input	Before (ticket)	Now (observed 2026-07-31)	HTTP	Leak?
Malformed UUID path param	GET /account/by-company/abc	500 + psycopg2 SQL leak	{"error":"Invalid UUID format: badly formed hexadecimal UUID string","success":false}	400	none
Negative integer path param	GET /company/-1/slds	500 + psycopg2 SQL leak	{"error":"Invalid UUID format: badly formed hexadecimal UUID string","success":false}	400	none
Negative pagination offset	POST /v2/issues/list page=-1	500 "OFFSET must not be negative" (SQL leaked)	200 — clamped, returns items {data: {items,page,page_size,total}}	200	none
Non-numeric page	POST /v2/issues/list page=abc	500 "unsupported operand type(s) for -: 'str' and 'int'"	200 — clamped, returns items	200	none
Negative page_size	POST /v2/issues/list page_size=-5	500 "LIMIT must not be negative" (SQL leaked)	200 — clamped, returns items	200	none
Non-numeric page_size	POST /v2/issues/list page_size=lots	500 "invalid literal for int()"	200 — clamped, returns items	200	none
Missing required field	POST /task/create {} (null sld_id)	500 NotNullViolation (SQL leaked)	{"error":"Missing required field: sld_id"}	400	none
Bad UUID in body	POST /task/create sld_id="not-a-uuid"	500 InvalidTextRepresentation (SQL leaked)	{"error":"Invalid UUID format: badly formed hexadecimal UUID string"}	400	none
Wrong JSON shape	POST /task/create [1,2,3]	500 "'list' object has no attribute 'get'"	{"error":"Request body must be a JSON object"}	400	none
Bad UUID (issue create)	POST /issue/create sld_id="not-a-uuid"	400 — but body still leaked psycopg2 text	{"error":"badly formed hexadecimal UUID string","success":false}	400	none
Bad enum/UUID (issue)	POST /issue/create issue_class="not-a-uuid"	(same leak family)	{"error":"An internal error occurred.","success":false,"trace_id":"073d3cd8...350ea"}	400	none

Vector	Endpoint · input	Before (ticket)	Now (observed 2026-07-31)	HTTP	Leak?
create, alt path)					

Supplementary probes

Probe	HTTP	Leak?	Body
Truncated JSON — POST /task/create {"title":	400	none	Flask generic 400 page: "Failed to decode JSON object: Expecting value: line 1 column 11" (JSON parse position — not SQL/driver internals)
Control — POST /location/building/ {}	400	none	{"error":"Missing required field: name","success":false} — the reference-correct behavior, now matched surface-wide
Far-past-end page — page=999999	200	none	{"data":{"items": [], "page":999999, "page_size":25, "total":12}, "success":true} — safe empty page

Assessment against the ticket's Expected Result

Requirement	Status
Malformed / out-of-range input caught before the DB → 400 (or 404 for absent IDs)	MET
No 4xx/5xx response contains SQL, psycopg2/driver names, tracebacks, table/column names, or query structure	MET
Genuine server errors return a bare error + correlation/trace id, nothing else	MET — trace_id observed (e.g. 073d3cd8...350ea)
Abusive pagination degrades to 4xx or clamped 200 (never a SQL 500)	MET — clamped 200

Cross-check — repo STRICT gate (mvn test -DSTRICT_INPUT_VALIDATION=true)

InputValidationApiTest + ErrorContractApiTest, STRICT (every finding escalated to a hard fail): **8 of 9 tests green**. The three tests that cover *this ticket* — malformed-body-never-5xx, no-internal-leakage, abusive-list-params-never-5xx — and the malformed-path GET contract all **PASS** under STRICT. The single red is a **different, adjacent concern** (below), not the info-disclosure/crash defect this ticket is about.

Adjacent gap — still open, but NOT this ticket's defect

The create endpoints now reject *malformed* input (bad UUID, wrong JSON shape, missing key field `sld_id`) — but still **accept some invalid-but-well-formed** create payloads with `201` instead of `400`. No leak, no 5xx — this is validation *depth*, a separate finding from the Critical info-disclosure defect:

Create payload (on the sandbox site)	Observed
task: wrong field types (task_type=int, title=int)	201 ACCEPTED
task: missing required 'title'	201 ACCEPTED
issue: invalid status enum 'BOGUS_STATUS'	201 ACCEPTED
issue: missing required 'issue_class'	201 ACCEPTED

Recommend tracking as its own follow-up (weak server-side field/enum validation on create) — it is materially lower severity than the SQL-leak defect and carries no information-disclosure risk. Test-created records self-clean; sandbox issue residue = 0.

Minor observations (non-blocking, not the security defect)

- The `issue/create` bad-UUID (alt path) returns message "An internal error occurred." on an HTTP **400** — sanitized and safe, but the wording reads like a 5xx; a "bad UUID" message would be clearer. No leak, so cosmetic only.
- Truncated-JSON returns Flask's default HTML 400 page rather than the app's JSON error envelope — inconsistent shape, but contains no internals and is not a 5xx.

Method: each vector was sent from an authenticated browser session (cookie auth) to the live QA API, and the raw response body was tested against the repo's leak pattern `psycpg2 | sqlalchemy | Traceback | File "/" | relation " | column " | SELECT...FROM | line N, in | InvalidTextRepresentation | NotNullViolation | ProgrammingError | OperationalError`. Cross-checked by the repo's `InputValidationApiTest + ErrorContractApiTest` (`mvn test -DSTRICT_INPUT_VALIDATION=true`). No probe created a record (all failed validation before insert).